
第 11 章 安全风险评估和等级保护作业和答案

一、填空题

- 1、信息系统建设的起点和源头是信息系统安全风险评估。
- 2、信息系统安全风险分析涉及资产、威胁、脆弱性等三个基本要素。
- 3、评价资产的三个安全属性是保密性、完整性、可用性。
- 4、威胁的基本属性包括威胁主体、资源、动机、途径。
- 5、信息系统基本安全需求包含基本安全技术需求和基本管理要求。
- 6、基本安全技术需求包含物理安全、网络安全、主机安全、应用安全和数据安全等 5 个层面。
- 7、基本管理要求包括安全管理制度、安全管理机构、人员安全管理、系统建设管理和系统运维管理等 5 个方面

二、选择题（包括单选和多选）

- 1、残余风险是由以下原因造成（ ABC ）
 - A. 安全措施不当造成的；
 - B. 安全措施失效造成的；
 - C. 综合考虑了安全成本与效益后未去控制造成的；
 - D. 组织机构变化后，引入的风险。
- 2、以下安全措施属于预防性安全措施的有（ ABD ）
 - A. 防火墙；
 - B. 入侵检测；
 - C. 入侵容忍；
 - D. 访问控制
- 3、以下说法正确的是（ AB ）
 - A. 根据威胁及威胁利用脆弱性的难易程度判断安全事件发生的可能性；
 - B. 根据威胁出现的频率和脆弱性的严重程度判断安全事件发生的可能性；
 - C. 根据资产的价值和脆弱性的严重程度判断安全事件发生的可能性；
 - D. 根据威胁出现的频率和资产的价值判断安全事件发生的可能性

4、以下说法正确的是（ ABDE ）

- A. 脆弱性识别需要具体到每个资产或组件上；
- B. 安全措施的确证不需要具体到每个资产或组件上；
- C. 保护性安全措施可以降低安全事件发生的可能性；
- D. 保护性安全措施可以减少安全事件发生后对组织或系统造成的影响；
- E. 安全措施的实是是以减少脆弱性或降低安全事件发生的概率为目标的。

5、以下说法正确的是（ D ）

- A. 资产的重要性可以选择保密性、完整性和可用性上的任何一个赋值表示；
- B. 资产的重要性只能综合考虑保密性、完整性和可用性上赋值；
- C. 资产的重要性取决于资产的经济价值；
- D. 资产的重要性取决于资产的价值。

6、以下哪种情况会出现欠保护（ B ）

- A. 在资产价值级别大于威胁级别的情况下，以威胁级别作为信息系统（安全域）的安全保护等级；
- B. 在资产价值级别小于威胁级别的情况下，以资产价值级别作为信息系统（安全域）的安全保护等级；
- C. 在资产价值级别与威胁级别相同的情况下，该级别则为信息系统（安全域）的安全保护等级；
- D. 根据信息系统安全等级不同，采用不同的安全措施。

三、简答题

1、信息系统安全风险评估的概念？

答：信息系统安全风险评估是根据国家有关信息安全技术标准，对信息系统及其处理、传输和存储信息的安全属性进行科学评估的过程，即评估信息系统的脆弱性，所面临的威胁以及脆弱性被威胁源利用后对系统造成的负面影响，并根据安全事件发生的可能性和负面影响来识别信息系统的安全风险。

2、在什么情况下进行信息系统安全风险评估？

答：

- （1） 在设计规划或升级信息系统时。前者是在信息系统建立时，通过信息系统安全风险评估，将安全体系或机制的建设和系统的建设同步进行，有利于为信息系统建立完整和全面的防护体系；后者是在现有的信息系统升级时，其安全威胁和安全需求可能发生改变，此时需要对其风险重新评估。
- （2） 目前的信息系统需要增加新的应用或新的扩充时，其运行环境可能发生变化，造成其威胁源发生变化，从而需要重新对其进行风险评估，进一步确定新的安全需求。
- （3） 发生一次安全事件后，意味着原有的安全威胁分析不够全面，有所遗漏，此时需要重新评估其风险。
- （4） 组织发生结构性变动时，信息系统的运行环境将发生变化，管理人员和运行、使用系统的人员可能发生变化，需要对信息系统安全风险重新评估。
- （5） 按照某些规定或特殊要求，对信息系统的安全进行评估时。

3、信息系统安全风险评估的可控性原则是什么？

答：在风险评估项目实施过程中，应严格按照标准的项目管理方法对服务过程、人员和工具进行控制，以确保风险评估实施过程中的可控和安全。

- （1） 服务可控性。评估放应实现在评估工作沟通会议中，向用户介绍评估服务流程，明确需要得到被评估组织写作的工作内容，确认安全评估服务工作的顺利进行。
- （2） 人员与信息可控性。所有参与评估的人员均应进行严格的资格审查和备案，明确其职责分工，应签署保密协议，以保证项目信息的安全；应对工作过程数据和结果数据严格管理，未经授权不得泄露给任何单位和个人。
- （3） 过程可控性。应按照项目管理的要求，成立项目实施团队，采用项目组长负责制，达到项目过程的可控。

-
- (4) 工具可控性。安全评估人员所使用的评估工具应该事先告诉用户，并在实施前获得用户的许可，包括产品本身，测试策略等。

4、什么情况下会造成残余风险？

答：

- (1) 由于安全措施不当或无效造成的；
- (2) 综合考虑了安全成本和效益后未去控制的风险。

5、风险评估工具选择的原则？

答：

- (1) 实际需要原则。首先必须清楚风险评估工具的运行平台和应用平台，选购时要注意工具是否能够检测最新操作系统所特有的安全问题，同时还要留意工具除了对 TCP/IP 协议进行分析外，还应该能够对其他网络协议进行分析。
- (2) 试用原则。评估一个工具是否满足用户的要求，最好的办法是在购买前，测试或试用一下，在用户的实际环境和系统下看看工具能否有效运行。
- (3) 实用原则。为了提高实用性，风险评估工具不仅能够找出特定系统的安全弱点，帮助管理员修补漏洞，而且能够提供风险分析报告。一个好的风险评估工具具有良好的人机界面，具有依托互联网的强大服务功能，能够通过互联网为用户提供有关漏洞的详细说明、风险程度、修补措施等。
- (4) 满足脚本数量与更新速度要求。评估工具的脚本数量并不一定与漏洞的数量成正比。优秀的风险评估工具能够将每一种漏洞链接到一个标准的漏洞案例上。必须留意工具的更新频率，看它是自动更新的，还是手工更新的，以及发现威胁后，它需要多长时间才能推出新版本。
- (5) 支持不同级别的入侵检测。所有风险评估工具都有这样的警告：入侵检测过程可能产生 DoS 攻击或导致受测试系统挂起。一般的，在高访问量期间，对担负关键任务的系统不应运行风险评估工具。原因是风险评估

工具本身可能引起服务终端或系统死机。大多数高级的风险评估工具允许执行侵害程度较小的入侵测试，以免造成系统运行终端。

四．计算题

1、假设：某信息系统有 3 个重要的资产 $A_1=2$ ， $A_2=1$ ， $A_3=3$ ，，其中 A_1 面临三个主要威胁 $T_1=1$ ， $T_2=5$ ， $T_3=4$ ； A_2 面临两个主要威胁 $T_4=3$ ， $T_5=4$ ； A_3 面临两个主要威胁 $T_6=3$ ， $T_7=4$ 。威胁 T_1 可以利用资产 A_1 存在的一个脆弱性 $V_1=3$ ；威胁 T_2 可以利用资产 A_1 存在的两个脆弱性 $V_2=1$ ， $V_3=5$ ；威胁 T_3 可以利用资产 A_1 存在的一个脆弱性 $V_4=4$ 。威胁 T_4 可以利用资产 A_2 存在的一个脆弱性 $V_5=4$ ；威胁 T_5 可以利用资产 A_2 存在的一个脆弱性 $V_6=3$ 。威胁 T_6 可以利用资产 A_3 存在的一个脆弱性 $V_7=2$ ；威胁 T_7 可以利用资产 A_3 存在的一个脆弱性 $V_8=3$ 。

计算各资产在不同威胁和脆弱性下的风险值，判定各风险值的风险等级。
答：

资产	威胁	脆弱性	发生概率 L	损失 F	风险值 R	等级
资产 $A_1=2$	$T_1=1$	$V_1=3$	$\sqrt{3}$	$\sqrt{6}$	$3\sqrt{2}$	1
	$T_2=5$	$V_2=1$	$\sqrt{5}$	$\sqrt{2}$	$\sqrt{10}$	1
	$T_2=5$	$V_3=5$	5	$\sqrt{10}$	$5\sqrt{10}$	4
	$T_3=4$	$V_4=4$	4	$2\sqrt{2}$	$8\sqrt{2}$	3
资产 $A_2=1$	$T_4=3$	$V_5=4$	$2\sqrt{3}$	2	$4\sqrt{3}$	2
	$T_5=4$	$V_6=3$	$2\sqrt{3}$	$\sqrt{3}$	6	2
资产 $A_3=3$	$T_6=3$	$V_7=2$	$\sqrt{6}$	$\sqrt{6}$	6	2
	$T_7=4$	$V_8=3$	$2\sqrt{3}$	3	$6\sqrt{3}$	2

假设判定等级是

1-5 1 级； 6-10 2 级； 11-15 3 级； 16-20 4 级； 21-25 5 级